

Pass the word around

Although its demise has long been predicted — and wished for by many — the password is still the most common form of identity authentication in use. At first sight, the use of a password for authentication seems straightforward and secure; but in practice the system has many limitations and inherent problems. We are forced to continue to use them for the foreseeable future, so in this article we will have a look at some of the problems and suggest some solutions.

The single most important problem, of course, is memorability. One person known to us, we'll call him John, can illustrate the worst way to use passwords. Until recently, he used exactly the same user name and password for any internet site that required registration. One day he wanted to look something up on a specialist knife site in the US. It required registration, and he used his usual login. Luckily for him, he very quickly discovered that orders were being placed using his eBay account for items to be dispatched to Africa. Also luckily for him, Ebay responded quickly in freezing his account and preventing any real harm from being done.

What had happened appears to have been this: the knife site had some kind of automated system that would collect user names and passwords and then try them out, against eBay, Amazon, banks and other such online stores. Once it found a hit, it then started making orders — probably by alerting one or more humans with the successfully stolen login information.

The first rule with passwords clearly has to be to differentiate between sites that involve financial transactions and any other kind of important personal information, and all others. For example, you may well need to register to access some newspaper sites, or other general information sites. These organisations request registration in order to keep a check on the number and types of people visiting their sites in order to give a better service. It hardly matters if you use the same login and relatively simple, easy to remember, passwords with these sites. There is usually no risk of loss of personal information that might lead to theft of goods or money.

However, the situation is very different with sites that involve financial transactions. These need to have strong passwords — that subject will be discussed shortly — and preferably a different password for each site. These

passwords should also be changed at reasonable intervals. Make sure that you do not use the same password that you have for a transactional website for any other website — news, email, and so forth. Keep them secure, and do not write them down. Ever.

A strong password is one that is difficult to guess or search for automatically. The problem, of course, is that the stronger and more random a password is, the more difficult it is to remember. Simply using long words from your natural language is not good enough. You count this in different ways, but it is commonly considered that the English language consists of between one and two hundred thousand words. It does not take a modern computer very long to go through such a list. One email company had a reasonable attempt at improving on natural language passwords about 20 years ago: each password issued to users consisted of eight letters in pairs, forming four syllables. The structure was like this: “gedovo zu”. This was relatively easy to remember and was not part of any natural language set. Such passwords are suitable for use with low risk websites, but are not really strong enough for financial sites.

The strength of a password lies in its entropy, or randomness. A similar method to the one just described that produces much stronger passwords involves the use of mnemonic phrases — these tend to be relatively easy to remember, and highly entropic. For example, the phrase “Robert likes to have two sugars in his coffee” would yield “Rlth2sihc”. That has nine characters, one is upper case, and one other is a numeral. This is much stronger than the more simple “gedovo zu”.

The entropy of a password depends on the number of possible combinations. If you just stick to lower case letters, a four character password has a total of 26^4 (26 to the power 4) combinations: 4,56,976. This seems like a large number, but a computerised search could zip through these in little time, and anyway, most combinations would be difficult to remember, and so would end up not being used. You increase the entropy by increasing both the number of characters in the password and the number of character sets from which they are drawn. So, a strong password should include at least eight characters, drawn from both upper and lower case letters, numerals and other characters, such

as &, @, %, where permissible.

You also need to be protective of your password once you are satisfied that it is strong and have memorized it. In 2004, a survey was conducted at a London railway station in which people were asked for their password — presumably in the interests of scientific enquiry — in return for a chocolate Easter egg. 71 per cent cooperated. Of course, we cannot know how many lied, but even so this is a disturbing figure. It had been 90 per cent the year before, but then the gift had been an obviously more attractive cheap pen. There is no reason why you should ever give your password to anybody — that defeats the whole object of having a password in the first place. Some companies — utility companies have been known to do this, for example — ask for passwords over the telephone. Always refuse to comply. Never tell your password(s) to anybody.

It is well worth taking the trouble with financial sites to memorize a couple of passwords that are specifically difficult to remember — without any common phrase or letter combination. But what if you need to remember more than just a couple? Many banks nowadays are requiring two passwords — one for login and one for transactions — you also may well have more than one bank account, perhaps also a credit card account or two, and then there are shopping sites like eBay. It can soon become quite a list of sites that require strong passwords, and the last thing you want to do is write them down.

The present writer was once asked to help a colleague with a problem concerning his laptop. This was a senior executive in a publishing company; such people often consider technical writers to be extensions of the IT department. This chap's password for his email system was written in indelible ink on the outside of his laptop. That is the worst example, but also writing passwords down anywhere is a bad idea; a small piece of paper kept under your mousemat, or maybe in your wallet, and so on. Never write them down. Never.

One possible way of recording a multiplicity of strong passwords is in an encrypted file, produced with software such as WinRAR. With compression and archiving software such as WinRAR you have the option to password protect the file so that only somebody with the password can open it and view the contents. However, you need to use a strong password. A useful exercise to go through is to download password cracking software and try it out. This is software that is usually described as helping people who have forgotten their password. It will run through all possible combinations using the character sets and password lengths that you define.

Try one of these out with a file protected by a weak password; once you have seen how quickly this can be done, you will take much more care to use strong passwords in future. One further point with this method is that when you view the file, do just that and only that, and do not extract to disk unless you need to edit it and add something new. If you do have to do that, also make sure not only that you delete the file after it has been re-archived, but that you immediately create a new file of the same name and at least the same size in the same directory — this can simply consist of rubbish, and should ensure that the information in the file will be removed from the hard drive. You can immediately delete it. There are also utilities that you can download that will do this for you, when you wish to delete a sensitive file; they are probably more certain to delete all data, but the method just given should work on most occasions. And one final point, do not name your archive “my_passwords.rar” or anything even remotely similar! ■

Huntkey 航嘉
Professional power supply provider



Vista Power Series

Meant for vista operating system with high end graphic cards (85% high efficiency, higher reliability with built in protection, fan speed auto control)



Green star Power Series

Saving energy is the key (Low standby by power < 1w, 85% high efficient performance)



DH Power Series

PSU for digital home systems (Supports multi USB function for MP4, Digital camera, camcorder etc., low power consumption on standby)



Titan Power Series

For the high end server systems (Comply with ATX12V & EPS12V V2.91 support PC, IPC, workstation, server), active power factor correction, 82% high efficiency performance)

Marketed in India by



Regalator: Satya/Satyachand Pvt Ltd, Ph: 080-57601277, Vendor system, Ph: 080-34411999
Chennai: Delta Peripherals, Ph: 044-4810066, Kochi: Techie Instruments, Ph: 0495515294
Mumbai: Sujaywadekar, Ph: 022-26231866, Secunderabad: Entersystems, Ph: 040-27811788
www.iceindia.com Dealer supply by authorized